

SX

SentinelX External Exposure Intelligence Report

Passive Reconnaissance Assessment — Confidential

sign.dropbox.com

Generated: 2026-03-06 06:54 UTC

 ASSESSMENT METADATA	
ASSESSMENT TYPE	External Passive Reconnaissance
TARGET SCOPE	External passive reconnaissance of sign.dropbox.com and its publicly observable subdomain infrastructure
TIMESTAMP	2026-03-06T06:54:27.071783+00:00
SCANNER VERSION	SentinelX v1.2.0
ANALYST	SentinelX Automated Engine
METHODOLOGY	Passive external reconnaissance only. All data collected from publicly accessible sources including: HTTPS certificate inspection, HTTP response header analysis, DNS record enumeration, certificate transparency log queries (crt.sh), favicon hash fingerprinting, and TCP port probing of well-known service ports. No authentication, exploitation, or active intrusive testing was performed at any stage.

EXPOSURE SCORE

Composite 1–10 Risk Metric



Medium Exposure

Moderate external exposure. Several risk indicators were identified. Structured remediation within 60 days is recommended.

4 / 10

EXPOSURE SCORE METHODOLOGY

The Exposure Score is a 1–10 composite metric representing the organisation's external attack surface as observed from a fully passive reconnaissance perspective. Higher scores indicate broader, more exploitable exposure.

+2 Expired TLS Certificate

An expired certificate disables transport security warnings and signals operational neglect.

+2 High-Risk Pattern Subdomains Detected

Subdomains matching patterns such as 'dev', 'admin', 'staging' indicate pre-production or privileged surfaces.

+2 Sensitive Ports Publicly Reachable

Ports such as 22 (SSH), 3306 (MySQL), 3389 (RDP) present direct attack vectors for credential attacks.

+1 Missing HSTS Header

Absence of Strict-Transport-Security enables protocol downgrade and session interception.

+1 Missing Content-Security-Policy

Absence of CSP leaves the application unprotected against cross-site scripting injection.

+1 Missing X-Frame-Options

Without frame protection, authenticated interfaces are vulnerable to clickjacking.

+1

Large Subdomain Attack Surface (>5 hosts)

A broad subdomain footprint increases enumeration potential and the probability of a misconfigured host.

Low (1-3)

Minimal observable exposure. Basic hygiene controls appear to be in place.

Medium (4-7)

Moderate exposure. Several risk indicators present; structured remediation recommended within 60 days.

High (8-10)

Significant external exposure. Immediate prioritised remediation required.

ATTACK SURFACE OVERVIEW

1

Subdomains Discovered

1

Sensitive Open Ports

1

Critical Headers Missing

0

High-Risk Subdomains

✓ Valid

TLS Certificate Status

8

Technology Indicators

Amazon CloudFront

Caching Layer (Varnish/CloudFront)

Express.js

HubSpot CMS

Ruby on Rails

Server: cloudflare

Webflow

jQuery

High	1	1
Medium	1	1
Low	2	2

EXECUTIVE SUMMARY**HIGH RISK**

Passive external reconnaissance of sign.dropbox.com identified a medium exposure posture across 1 resolvable subdomain(s). The assessment surfaced 1 high-severity and 1 medium-severity indicators warranting structured remediation attention.

PRIMARY RISK #1

Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploitation, and lateral movement.

PRIMARY RISK #2

HSTS header absent — browsers may permit unencrypted HTTP connections, exposing session tokens to network-level interception.



Prioritise remediation of High-severity findings within the next 30 days. Schedule a follow-up passive assessment in 90 days to validate posture improvement.

This assessment relied exclusively on passive, publicly observable signals. No intrusive testing, exploitation, or active probing was performed at any stage.

SECURITY FINDINGS

1. Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploi

A05:2021 – Security Misconfiguration

HIGH

TECHNICAL DESCRIPTION

Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploitation, and lateral movement.

SECURITY IMPACT

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

BUSINESS IMPACT

DataExposure Risk	Dependent on service exposed — evaluate data access scope.
Credential Compromise Risk	Possible if authentication interfaces or credentials are reachable.
Infrastructure Enumeration Risk	External adversaries can map service topology from observable signals.
Compliance Risk	May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
Reputation Risk	Publicly observable misconfigurations erode technical credibility with enterprise buyers.

Threat Scenario

An adversary performing targeted reconnaissance identifies this condition and incorporates it into a structured attack plan, using it as an initial foothold for credential theft, data exfiltration, or further lateral movement.

Remediation Recommendation

Review this finding with your infrastructure team and apply targeted hardening controls.

Technology-Specific Implementation

Apply remediation according to your web server and framework documentation.

2. HSTS header absent — browsers may permit unencrypted HTTP connections, exposing session tokens to network-level interception

A02:2021 – Cryptographic Failures

MEDIUM

TECHNICAL DESCRIPTION

HSTS header absent — browsers may permit unencrypted HTTP connections, exposing session tokens to network-level interception.

SECURITY IMPACT

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

BUSINESS IMPACT

DataExposure Risk	Dependent on service exposed — evaluate data access scope.
Credential Compromise Risk	Possible if authentication interfaces or credentials are reachable.
Infrastructure Enumeration Risk	External adversaries can map service topology from observable signals.
Compliance Risk	May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
Reputation Risk	Publicly observable misconfigurations erode technical credibility with enterprise buyers.

Threat Scenario

An adversary positioned on the same network segment as a target user (hotel Wi-Fi, conference network) initiates an SSL Strip attack using a tool such as sslstrip. Because HSTS is absent, the victim's browser accepts an unencrypted HTTP connection. The attacker captures the session cookie from the HTTP request and replays it against the application's authenticated API, achieving full account access.

Remediation Recommendation

In Cloudflare Dashboard → SSL/TLS → Edge Certificates → Enable HSTS with max-age=31536000 and includeSubDomains. General guidance: Add 'Strict-Transport-Security: max-age=31536000; includeSubDomains; preload' to all HTTPS responses. Submit the domain to the HSTS preload list at hstspreload.org once confirmed stable.

Technology-Specific Implementation

In Cloudflare Dashboard → SSL/TLS → Edge Certificates → Enable HSTS with max-age=31536000 and includeSubDomains.

3. Valid TLS endpoint reachable. Certificate chain and expiry details collected.

A02:2021– Cryptographic Failures

LOW

TECHNICAL DESCRIPTION

Valid TLS endpoint reachable. Certificate chain and expiry details collected.

SECURITY IMPACT

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

BUSINESS IMPACT

DataExposure Risk	Dependent on service exposed — evaluate data access scope.
Credential Compromise Risk	Possible if authentication interfaces or credentials are reachable.
Infrastructure Enumeration Risk	External adversaries can map service topology from observable signals.
Compliance Risk	May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
Reputation Risk	Publicly observable misconfigurations erode technical credibility with enterprise buyers.

 Threat Scenario

An adversary performing targeted reconnaissance identifies this condition and incorporates it into a structured attack plan, using it as an initial foothold for credential theft, data exfiltration, or further lateral movement.

 Remediation Recommendation

Review this finding with your infrastructure team and apply targeted hardening controls.

 Technology-Specific Implementation

Apply remediation according to your web server and framework documentation.

4. Technology stack fingerprinted (8 indicators). Public exposure of framework and version information may inform targeted

A06:2021 – Vulnerable and Outdated Components

LOW

TECHNICAL DESCRIPTION

Technology stack fingerprinted (8 indicators). Public exposure of framework and version information may inform targeted research.

SECURITY IMPACT

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

BUSINESS IMPACT

DataExposure Risk	Dependent on service exposed — evaluate data access scope.
Credential Compromise Risk	Possible if authentication interfaces or credentials are reachable.
Infrastructure Enumeration Risk	External adversaries can map service topology from observable signals.
Compliance Risk	May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
Reputation Risk	Publicly observable misconfigurations erode technical credibility with enterprise buyers.

Threat Scenario

The detected framework version is cross-referenced with CVE databases, revealing a known Remote Code Execution vulnerability. The attacker downloads a public proof-of-concept and validates it against the target without triggering any security alerts. A reverse shell is established, granting operating system level access to the application server and all data it can reach.

Remediation Recommendation

Suppress version-revealing response headers (Server, X-Powered-By, X-Generator). In Nginx: `server_tokens off`; In Apache: `ServerTokens Prod`; `ServerSignature Off`. Ensure all detected frameworks are on current stable versions.

Technology-Specific Implementation

Apply remediation according to your web server and framework documentation.

POTENTIAL ATTACK PATHS

 POTENTIAL ATTACK PATHS

How findings chain into business impact

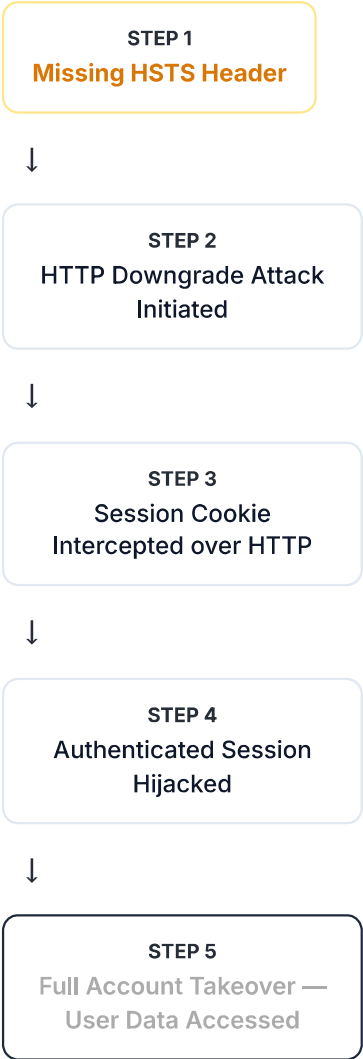
HIGH

Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploi



MEDIUM

HSTS header absent — browsers may permit unencrypted HTTP connections, exposing session tokens to network-level intercept



TECHNICAL APPENDIX

A.1 — TLS CERTIFICATE DETAILS

ATTRIBUTE	VALUE
Reachable	Yes
Subject (CN)	sign.dropbox.com
Issuer (CA)	Amazon ECDSA 256 M02
Valid From	Jun 26 00:00:00 2025 GMT
Valid To	Jul 25 23:59:59 2026 GMT
Days Remaining	141
TLS Version	TLSv1.3
Cipher Suite	TLS_AES_128_GCM_SHA256
Certificate Expired	No

A.2 — SECURITY HEADER ANALYSIS

HEADER	PRESENT	VALUE
Strict-Transport-Security	No	—
Content-Security-Policy	Yes	frame-ancestors 'self'
X-Frame-Options	Yes	SAMEORIGIN
X-Content-Type-Options	No	—
Referrer-Policy	No	—
Permissions-Policy	No	—
Cross-Origin-Opener-Policy	No	—
Cross-Origin-Resource-Policy	No	—

A.3 — OPEN PORT ENUMERATION

PORT	SERVICE	EXPOSURE CLASSIFICATION
21	FTP	High Exposure
80	HTTP	Standard Web
443	HTTPS	Standard Web

A.4 — SUBDOMAIN ENUMERATION

1 host(s) resolved

sign.dropbox.com

A.5 — DNS RECONNAISSANCE

A IPV4 ADDRESS RECORDS

99.86.20.60 99.86.20.6 99.86.20.55 99.86.20.100

MX MAIL EXCHANGE RECORDS

mx.a.mailgun.org mxb.mailgun.org

TXT TEXT RECORDS

#	RECORD VALUE
1	google-site-verification=Ve7ZdADvfD1QSNmkBR2vYUbrJ1zGZcfj7XhlmP97R9o
2	v=spf1 include:mailgun.org ~all

SPF RECORD

v=spf1 include:mailgun.org ~all

DMARC RECORD

Not found — without DMARC, phishing emails spoofing this domain may not be rejected.

A.6 — CERTIFICATE TRANSPARENCY (CRT.SH)

1 host(s) via CT logs

The following subdomains were discovered passively via certificate transparency log queries (crt.sh). CT logs record all issued certificates, revealing historical and current subdomain infrastructure.

sign.dropbox.com

DISCLAIMER & LIMITATIONS

This report was generated by SentinelX v1.2.0 using exclusively passive, non-intrusive reconnaissance techniques. All data was collected from publicly observable sources including certificate transparency logs, public DNS

records, HTTP response headers, and TCP port availability. No exploitation, credential testing, or authenticated access was performed. Findings represent risk indicators observable from the public internet and do not constitute a complete security assessment. A full penetration test by qualified security professionals is recommended to validate and prioritise these findings.

SentinelX External Exposure Intelligence Engine — Confidential Report — 2026-03-06 06:54 UTC